



Certified Penetration Testing Professional

Nikto Cheat Sheet

Nikto

Source: <https://cirt.net>

Nikto is an Open Source (GPL) web server vulnerability scanner that can perform wide-ranging tests against web servers of over 6700 potentially dangerous files/CGIs and can check for any older versions of over 1250 servers, and version specific problems on over 270 servers. It also checks for server configuration items, HTTP server options, captures, and prints any cookies received and tries to identify any newly installed web servers and software.

1. [Nikto Parameters](#)
2. [Types of Display Options](#)
3. [Types of Evasion Options](#)
4. [Types of Format Options](#)
5. [Types of Mutate Options](#)
6. [Types of Tuning Options](#)
7. [Nikto Variables](#)
8. [Nikto Commands](#)

Nikto Parameters

Parameter	Description
-ask+	Ask about submitting updates: yes (ask about each-- the default), no (don't ask, just send), auto (don't ask, just send)
-Cgidirs+	Scan CGI directories by using special words "none" or "all"
-config+	Use an alternative config file instead of the nikto.conf file
-dbcheck	Verify the scan databases for syntax errors
-Display+	Use to control the output of Nikto
-evasion+	Input the LibWhisker encoding/evasion technique to use
-findonly	Identify the HTTP(S) ports without performing security scan
-host+	IP address, hostname or text file of hosts
-Help	Show extended help information
-id	Give ID and password for host Basic host authentication. The format is "id:password"
-IgnoreCode	Ignore HTTP codes as negative responses
-list-plugins	Display all plugins that Nikto can run against targets
-maxtime+	Retrieves maximum execution time per host, in seconds
-mutate+	Input mutation technique. This will cause Nikto to combine tests or attempt to guess values
-mutate-options	Input extra information for mutates, e.g. a dictionary file
-nolookup	Avoid performing name lookups on IP addresses
-nointeractive	Disable interactive features
-noss1	Do not use SSL to connect to the server
-no404	Disable 404 (file not found) checking
-output+	Specify the file to write output
-Plugins+	Give plugins to run on the specified targets
-port+	Specify TCP port(s) to target
-Pause+	Seconds (integer or floating-point) to delay between each test
-root+	Prepend the value specified to the beginning of every request
-ssl	Only check SSL on the ports specified

-Save	Save request/response of findings to this directory
-timeout+	Seconds to wait before timing out a request. The default timeout is 10 seconds
-Tuning+	Control the test that Nikto will use against a target
-Userdbs	Load user-defined databases instead of standard databases
-until	Execute until the specified time or duration, then pause
-update	Update the plugins and databases directly from cirt.net
-useproxy	Use the HTTP proxy defined in the configuration file
-Version	Display the Nikto software, plugin and database versions
-vhost+	Specify the Host header to be sent to the target

Types of Display Options

Parameter	Description
-Display 1	Shows redirects, that displays all requests which receive a "redirect" response from the server
-Display 2	Displays cookies received from a remote host
-Display 3	Retrieves all 200/OK responses
-Display 4	Retrieves URLs which require authentication
-Display D	Debug output. Show debug output, which shows the verbose output and extra information such as variable content
-Display E	Display details of all HTTP errors
-Display P	Displays progress to STDOUT
-Display S	Scrub output of IPs and hostnames
-Display V	Gives verbose output

Types of Evasion Options

Parameter	Description
-evasion 1	Random URI encoding (non-UTF8)
-evasion 2	Directory self-reference (/./)

-evasion 3	Premature URL ending
-evasion 4	Prepend long random string
-evasion 5	Fake parameter
-evasion 6	TAB as request spacer
-evasion 7	Change the case of the URL
-evasion 8	Use Windows directory separator (\)
-evasion A	Use a carriage return (0x0d) as a request spacer
-evasion B	Use binary value 0x0b as a request spacer

Types of Format Options

Parameter	Description
-Format csv	Comma-separated list
-Format htm	HTML report
-Format msf+	Log to Metasploit
-Format nbe	Nessus NBE format
-Format txt	Text report
-Format xml	XML report

Types of Mutate Options

Parameter	Description
-mutate 1	Test all files with all root directories
-mutate 2	Guess for password file names
-mutate 3	Enumerate usernames via Apache (/~user type requests).
-mutate 4	Enumerate usernames via cgiwrap (/cgi-bin/cgiwrap/~user type requests)
-mutate 5	Attempt to brute force sub-domain names assume that the hostname is the parent domain
-mutate 6	Attempt to guess directory names from the supplied dictionary file

Types of Tuning Options

Parameter	Description
-Tuning 0	File Upload
-Tuning 1	Interesting File / Seen in logs
-Tuning 2	Misconfiguration / Default File
-Tuning 3	Information Disclosure
-Tuning 4	Injection (XSS/Script/HTML
-Tuning 5	Remote File Retrieval
-Tuning 6	Denial of Service. Resource allows a denial of service against the target application
-Tuning 7	Remote File Retrieval - Server Wide
-Tuning 8	Command Execution / Remote Shell
-Tuning 9	SQL Injection
-Tuning a	Authentication Bypass
-Tuning b	Software Identification
-Tuning c	Remote source inclusion
-Tuning x	Reverse Tuning Options

Nikto Variables

Variable	Description
CLI_OPTS=-output results.txt-Format text	Pass default options to the command line
NIKTODTD=docs/nikto.dtd	Path to the location of the DTD used for XML output
RFIURL=http://cirt.net/rfiinc.txt?	Specify full URL to a file for remote file inclusion
SKIPPORTS=21 111	Specify ports that would never be scanned
SKIPIDS=000045 000345	Specify a space-separated list of Test IDs (tids) that Nikto will not run on the system
DEFAULTHTTPVER=1.1	Defines the default version of HTTP used by Nikto

LW_SSL_ENGINE=auto	Use the specified SSL library instead of the default
PROMPTS=	Disable or Enable Nikto prompts
PROXYHOST= PROXYPORT= PROXYUSER= PROXYPASS=	Address, port and username password of a proxy to relay all requests through
STATIC-COOKIE="cookie1"="cookie value"; "cookie2"="cookie val"	Include the supplied cookie(s) to all requests made via Nikto
CHECKMETHODS=HEAD GET	Identify targets as webserver by sending a request to fetch the / URI via certain HTTP methods
EXECDIR=. PLUGINDIR=EXECDIR/plugins TEMPLATEDIR=EXECDIR/templates DBDIR=EXECDIR/databases DOCDIR=EXECDIR/docs	Find the location of Nikto, its plugins, databases, XML/HTML templates and documents.

Nikto Commands

Command	Description
<code>perl nikto.pl -h <Target IP></code>	Basic Nikto scan
<code>perl nikto.pl -h <Target IP> -p 443</code>	Scan a given port
<code>perl nikto.pl -h https:// <Target IP>:443/</code>	Scan a given URL
<code>perl nikto.pl -h <Target IP> -p 443 -ssl</code>	Scan port
<code>perl nikto.pl -h <Target IP> -mutate 3 -mutate-options user-list.txt</code>	Use -mutate parameter to perform complex tests
<code>perl nikto.pl -h <Target IP> -p 80,88,443</code>	Scan multiple ports

<pre>1) perl nikto.pl -h localhost -p 80 -useproxy</pre> <pre>2) ./nikto.pl -h localhost -useproxy http://localhost:8080/</pre>	1) Use the -useproxy option to relay all connections through the HTTP proxy specified in the configuration file 2) Use the -useproxy option with the proxy set as the argument
<pre>perl nikto.pl -h <Target IP> -Tunning x</pre>	Scan the target on a specified IP address with specific types of tests determined by the tuning options